Insper

Atividade em grupo — Gerenciamento de recursos em nuvem

Cybersegurança em Nuvem — Prof. Dr. Rodolfo Avelino

Objetivo

Gerenciar recursos na nuvem é saber quais recursos existem, quem (ou o que) pode acessá-los, como esse acesso é concedido, revisado e revogado, e como o uso de cada recurso é monitorado. Esta atividade retoma o ambiente que vocês construíram nos roteiros (servidor web e banco de dados em sub-rede privada, Guacamole como jump server, Cloudflare, Wazuh, CloudWatch e Zabbix) e usa esse ambiente como objeto de análise.

Como trabalhar

A atividade é feita em grupo, sobre o ambiente do próprio grupo. São duas questões para discussão. Ao final, haverá uma socialização comparando as escolhas dos grupos.

Questão 1 — Acesso administrativo e identidade sobre os recursos

Vocês centralizaram o acesso administrativo no Apache Guacamole e removeram os acessos diretos aos servidores. Com isso, o próprio Guacamole passou a ser um recurso crítico. Para os recursos do ambiente, respondam:

- quem ou o que acessa cada recurso e com qual privilégio;
- como esse acesso é concedido e como seria revisado ao longo do tempo;
- o que aconteceria se o Guacamole ou o token da API da Cloudflare fosse comprometido, e que medidas reduzem esse risco.

Insper

Relacionem a resposta com a escolha entre roles e usuários IAM e com o princípio do menor privilégio. Usem a tabela abaixo para organizar.

Recurso	Quem / o que acessa	Privilégio	Concessão e revisão	Se comprometido
Servidor web				
Banco de dados (sub-rede privada)				
Guacamole (jump server)				
Instância Wazuh / Zabbix				
Conta e token da API Cloudflare				

- **Privilégio:** o que aquela identidade pode fazer no recurso, e não apenas se tem acesso. Vale distinguir ler, escrever e administrar, e anotar se o privilégio é mais amplo do que a tarefa exige.
- **Concessão e revisão:** como esse acesso é criado (quem autoriza e por qual processo) e como ele é verificado e removido ao longo do tempo, quando deixa de ser necessário.
- **Se comprometido:** o que um atacante conseguiria fazer caso obtivesse aquele acesso, e qual seria o impacto para o restante do ambiente.

Questão 2 — Monitoramento do uso dos recursos

O ambiente tem três camadas de monitoramento: CloudWatch (métricas da infraestrutura), Zabbix (disponibilidade e consumo de recursos) e Wazuh (eventos de segurança), além da resposta automatizada via API da Cloudflare. Respondam:

- O Roteiro 1 encaminha os logs do CloudWatch para o Wazuh. O que se ganha ao concentrar esses registros no Wazuh em vez de analisá-los separado em cada ferramenta?

Insper

- Se vocês tivessem que explicar para a diretoria qual pergunta cada ferramenta responde (CloudWatch, Zabbix, Wazuh), o que diriam em uma frase para cada uma?

Entrega do grupo

1. A tabela da Questão 1 preenchida.
2. A resposta da Questão 2, indicando os sinais e a camada de monitoramento de cada um.
3. A ligação com um incidente do caso do grupo (HealthPlus ou MaisPlace): a forma como vocês gerenciam e monitoram os recursos teria evitado ou detectado mais cedo aquele incidente?